

CVEs más relevantes de la semana

Del 14/04/2026 al 21/04/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-27243

Descripción: Adobe Connect versions 2025.3, 12.10 and earlier are affected by a reflected Cross-Site Scripting (XSS) vulnerability.

If an attacker is able to convince a victim to visit a URL referencing a vulnerable page, malicious JavaScript content may be executed within the context of the victim's browser. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-14



CVE-2026-27245

Descripción: Adobe Connect versions 2025.3, 12.10 and earlier are affected by a reflected Cross-Site Scripting (XSS) vulnerability.

If an attacker is able to convince a victim to visit a URL referencing a vulnerable page, malicious JavaScript content may be executed within the context of the victim's browser. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-14



CVE-2026-27246

Descripción: Adobe Connect versions 2025.3, 12.10 and earlier are affected by a DOM-based Cross-Site Scripting (XSS) vulnerability. An attacker could exploit this issue by manipulating the DOM environment to execute malicious JavaScript within the context of the victim's browser. Exploitation of this issue requires user interaction in that a victim must visit a crafted webpage. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-04-14



CVE-2026-27303

Descripción: Adobe Connect versions 2025.3, 12.10 and earlier are affected by a Deserialization of Untrusted Data vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-04-14



CVE-2026-34615

Descripción: Adobe Connect versions 2025.3, 12.10 and earlier are affected by a Deserialization of Untrusted Data vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-04-14



CVE-2026-27304

Descripción: ColdFusion versions 2023.18, 2025.6 and earlier are affected by an Improper Input Validation vulnerability that could result in arbitrary code execution in the context of the current user. Exploitation of this issue does not require user interaction.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-04-14



CVE-2026-1555

Descripción: The WebStack theme for WordPress is vulnerable to arbitrary file uploads due to missing file type validation in the `io_img_upload()` function in all versions up to, and including, 1.2024. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution possible.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-3461

Descripción: The Visa Acceptance Solutions plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.1.0. This is due to the ``express_pay_product_page_pay_for_order()`` function logging users in based solely on a user-supplied billing email address during guest checkout for subscription products, without verifying email ownership, requiring a password, or validating ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-288

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-20147

Descripción: A vulnerability in Cisco ISE and Cisco ISE-PIC could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have valid administrative credentials. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this vulnerability by ...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-20180

Descripción: A vulnerability in Cisco Identity Services Engine (ISE) could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have at least Read Only Admin credentials. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this vuln...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-20184

Descripción: A vulnerability in the integration of single sign-on (SSO) with Control Hub in Cisco Webex Services could have allowed an unauthenticated, remote attacker to impersonate any user within the service. This vulnerability existed because of improper certificate validation. Prior to this vulnerability being addressed, an attacker could have exploited this vulnerability by connecting to a service ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-295

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-20186

Descripción: A vulnerability in Cisco Identity Services Engine (ISE) could allow an authenticated, remote attacker to execute arbitrary commands on the underlying operating system of an affected device. To exploit this vulnerability, the attacker must have at least Read Only Admin credentials. This vulnerability is due to insufficient validation of user-supplied input. An attacker could exploit this vuln...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-6388

Descripción: A flaw was found in ArgoCD Image Updater. This vulnerability allows an attacker, with permissions to create or modify an ImageUpdater resource in a multi-tenant environment, to bypass namespace boundaries. By exploiting insufficient validation, the attacker can trigger unauthorized image updates on applications managed by other tenants. This leads to cross-namespace privilege escalation, impact...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:L

Tipo: CWE-1220

Tecnología: No especificado

Publicado el: 2026-04-15



CVE-2026-4880

Descripción: The Barcode Scanner (+Mobile App) – Inventory manager, Order fulfillment system, POS (Point of Sale) plugin for WordPress is vulnerable to privilege escalation via insecure token-based authentication in all versions up to, and including, 1.11.0. This is due to the plugin trusting a user-supplied Base64-encoded user ID in the token parameter to identify users, leaking valid authentication tokens...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-40504

Descripción: Creolabs Gravity before 0.9.6 contains a heap buffer overflow vulnerability in the gravity_vm_exec function that allows attackers to write out-of-bounds memory by crafting scripts with many string literals at global scope. Attackers can exploit insufficient bounds checking in gravity_fiber_reassign() to corrupt heap metadata and achieve arbitrary code execution in applications that evaluate unt...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-40962

Descripción: FFmpeg before 8.1 has an integer overflow and resultant out-of-bounds write via CENC (Common Encryption) subsample data to libavformat/mov.c.

CVSS: 4.9 (MEDIUM)

Vector: CVSS:3.1/AV:L/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-6350

Descripción: MailGates/MailAudit developed by Openfind has a Stack-based Buffer Overflow vulnerability, allowing unauthenticated remote attackers to control the program's execution flow and execute arbitrary code.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-3596

Descripción: The Riaxe Product Customizer plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 2.1.2. The plugin registers an unauthenticated AJAX action ('wp_ajax_nopriv_install-imprint') that maps to the `ink_pd_add_option()` function. This function reads 'option' and 'opt_value' from `$_POST`, then calls `delete_option()` followed by `add_option()` using these attacker...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-33082

Descripción: DataEase is an open source data visualization analysis tool. Versions 2.10.20 and below contain a SQL injection vulnerability in the dataset export functionality. The expressionTree parameter in POST /de2api/datasetTree/exportDataset is deserialized into a filtering object and passed to WhereTree2Str.transFilterTrees for SQL translation, where user-controlled values in "like" filter terms are d...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-33122

Descripción: DataEase is an open-source data visualization and analytics platform. Versions 2.10.20 and below contain a SQL injection vulnerability in the API datasource update process. When a new table definition is added during a datasource update via /de2api/datasource/update, the deTableName field from the user-submitted configuration is passed to DatasourceSyncManage.createEngineTable, where it is subs...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-16



CVE-2026-34018

Descripción: An SQL injection vulnerability exists in CubeCart prior to 6.6.0, which may allow an attacker to execute an arbitrary SQL statement on the product.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-17



CVE-2026-6443

Descripción: The Accordion and Accordion Slider plugin for WordPress is vulnerable to an injected backdoor in version 1.4.6. This is due to the plugin being sold to a malicious threat actor that embedded a backdoor in all of the plugin's they acquired. This makes it possible for the threat actor to maintain a persistent backdoor and inject spam into the affected sites.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-506

Tecnología: No especificado

Publicado el: 2026-04-17



CVE-2026-5963

Descripción: EasyFlow .NET developed by Digiwin has a SQL Injection vulnerability, allowing unauthenticated remote attackers to inject arbitrary SQL commands to read, modify, and delete database contents.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-20



CVE-2026-5964

Descripción: EasyFlow .NET developed by Digiwin has a SQL Injection vulnerability, allowing unauthenticated remote attackers to inject arbitrary SQL commands to read, modify, and delete database contents.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-04-20



CVE-2026-39918

Descripción: Vvweb prior to 1.0.8.1 contains a code injection vulnerability in the installation endpoint where the subdir POST parameter is written unsanitized into the env.php configuration file without escaping or validation. Attackers can inject arbitrary PHP code by breaking out of the string context in the define statement to achieve unauthenticated remote code execution as the web server user.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-04-20



CVE-2026-6257

Descripción: Vvweb CMS v1.0.8 contains a remote code execution vulnerability in its media management functionality where a missing return statement in the file rename handler allows authenticated attackers to rename files to blocked extensions .php or .htaccess. Attackers can exploit this logic flaw by first uploading a text file and renaming it to .htaccess to inject Apache directives that register PHP-exe...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-04-20



CVE-2026-41329

Descripción: OpenClaw before 2026.3.31 contains a sandbox bypass vulnerability allowing attackers to escalate privileges via heartbeat context inheritance and senderIsOwner parameter manipulation. Attackers can exploit improper context validation to bypass sandbox restrictions and achieve unauthorized privilege escalation.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-648

Tecnología: No especificado

Publicado el: 2026-04-21



CVE-2026-5965

Descripción: NewSoftOA developed by NewSoft has an OS Command Injection vulnerability, allowing unauthenticated local attackers to inject arbitrary OS commands and execute them on the server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-04-21



Resumen del Reporte

CVEs analizados: 28

Promedio CVSS: 9.49

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

